Field Hours

CSCE 702 Law and Policy in Cybersecurity

Original notes for this site. Same topics as the catalog course. Not a reprint of another university's lectures, and not academic credit.

Lecture 1 · 90 minutes

Four slots or it is not a rule

You read a cyber policy as an instrument that grants authority, not as advice. The mechanism is a sentence that names 4 slots: who must act, which systems are in scope, what action they take, and by when. A memo that says only be careful fills 0 of those slots. This course is the graduate law and policy course, cross-listed as CYBR 602. You will practice on documents, not on slogans.

You test a draft by filling the 4 slots from the text alone. If the deadline slot is empty, the operator cannot know whether day 2 is late. Scope is a list you can audit: for example, 12 servers in one office, not the enterprise. You write the list. A policy that cannot be violated in a way you could show an auditor is not yet a policy. It is a wish with a letterhead.

A rule you could actually violate.

Who must act

Which systems are in scope

What action they take

By when

Twelve servers, no deadline

1. The draft names an operator and lists 12 servers. The action is retain admin logs.

2. The deadline slot is empty. You cannot tell whether day 2 is late, so the sentence is not finished.

3. You do not replace the list of 12 with the word enterprise. A slogan fills 0 of the 4 slots.

Problem 1. A memo says be careful with the enterprise and names no actor, no list, no action, and no deadline. How many of the 4 slots are filled?

Answer. 0. A policy sentence needs who, scope, action, and deadline. This course, CYBR 602, practices on documents that can be violated, not on slogans.

Problem 2. Scope is written as 12 servers, and the deadline slot is blank. Can the operator know whether day 2 is late?

Answer. No. Day 2 has nothing to be late against. You can audit the list of 12, and you still cannot apply a clock that was never written.

Lecture 2 · 90 minutes

A contract term you can fail

You turn a security need into a contract term you can accept or reject at procurement. The mechanism is an acceptance test written next to the term. Retain admin logs for 90 days is testable: on day 91 you either still have the log or you do not. A term that says use good security has no day count and no artifact, so you cannot score it. You require 1 test per requirement before you award the contract.

You separate a control from a product name. The contract should demand the log retention of 90 days, not a brand. A vendor paragraph that lists 8 features does not replace the test. During acceptance you sample 1 day of logs and you check the oldest record age against 90. If the oldest record is 10 days old, the delivery fails that term. You record the fail against the term number, not against a salesperson slide.

From a need to a scored delivery.

Write the numbered term -> Attach one acceptance test -> Sample the delivered artifact -> Score pass or fail

Day 91, or the oldest record

1. The term says retain admin logs for 90 days. The test is that a log from day 0 still exists on day 91.

2. You sample the delivery. The oldest record is 10 days old, which is not 90.

3. You fail that term number. The vendor's list of 8 features does not change the sample.

Problem 1. The term requires 90 days of admin logs. The oldest record in the delivery is 10 days old. Does the term pass, and what is the shortfall in days?

Answer. It fails. The shortfall is 80 days, because 90 minus 10 is 80. You record the fail against the term number. Eight advertised features are not the test.

Problem 2. The draft says use good security and names a product. Why is that not ready to award?

Answer. It has no day count and no artifact, so you cannot score it. You require 1 acceptance test per requirement. The control is the retention, such as 90 days, not the brand.

Lecture 3 · 90 minutes

The clock starts when you write discovery

Operations policy is a clock plus a role. The mechanism is a deadline measured from a time you wrote down. If the rule says 72 hours from discovery, and you recorded discovery at 09:00 on Monday, the report is due at 09:00 on Thursday, 72 hours later. Starting the clock at the press conference instead of at discovery makes a late report look timely. You name 1 incident commander who may start that clock.

You keep an operations log with 3 times: discovery, containment decision, and external notice. If discovery is hour 0 and notice is hour 80, you exceeded a 72-hour rule by 8 hours, and you write the 8. Do not backdate discovery to hour 8 so the subtraction looks like 72. A status meeting that produces no time entries does not operate the policy. You can have 5 meetings and still miss the only clock that matters.

Three times, then the subtraction.

1. Write the discovery time

2. Name one commander

3. Log the notice time

4. Subtract from the deadline

Notice at hour 80

1. Discovery is logged at hour 0 by the 1 incident commander. The rule allows 72 hours.

2. External notice goes out at hour 80. The overrun is 80 minus 72, which is 8 hours.

3. You write 8. You do not move discovery to hour 8 to make the gap look like 72. Five status meetings do not replace the log.

Problem 1. Discovery is hour 0, the rule is 72 hours, and notice goes out at hour 80. By how many hours is the notice late?

Answer. 8 hours. 80 minus 72 is 8. You write the 8. Backdating discovery to hour 8 would fake a gap of 72 and is not allowed.

Problem 2. Discovery was recorded at 09:00 Monday and the rule is 72 hours. When is the report due?

Answer. 09:00 Thursday. 72 hours after Monday 09:00 is Thursday 09:00. The clock starts at the discovery time you wrote, not at a later press conference. One commander owns that start.

Lecture 4 · 90 minutes

Silence is not a signature

Governance answers who may bind the organization. The mechanism is a signature authority table, not a chat channel. Suppose 3 roles exist: an operator who proposes, a security officer who reviews, and an executive who accepts residual risk. A change that ships with only the operator note has 1 signature of the 3 you required. You do not treat silence in the review meeting as the missing signature. Silence has no name and no date.

You review the table when a role is vacant. If the executive seat is empty for 14 days, residual-risk acceptance stops, because nobody holding that seat can sign. Borrowing the operator login to add the third name is not governance. You want the 3 names to be 3 people. A board slide that says security is a priority does not identify the signer. You can point at the table, or you do not have one.

What counts as binding the organization.

A real acceptance

Three distinct people

Name and date on each

Executive signs residual

Not acceptance

Silence in a meeting

A shared operator login

A slide with no signer

One signature of three

1. The change carries the operator's name and date. The reviewer and the executive lines are blank.

2. You count 1 signature of the 3 required. The change does not ship.

3. The executive seat has also been empty for 14 days, so residual-risk acceptance is stopped until that seat can sign as a different person.

Problem 1. The operator signed, the reviewer was silent, and the executive line is blank. How many of the 3 required signatures do you have?

Answer. 1. Silence is not a signature, because it has no name and no date. You need the operator, the security officer, and the executive as 3 people.

Problem 2. The executive seat is empty for 14 days. Someone uses the operator login to type the executive's name. Is residual risk accepted?

Answer. No. Acceptance stops while that seat is empty, and a borrowed login is not a second person. Fourteen days of vacancy does not create authority. A priority slide does not name a signer either.

Lecture 5 · 90 minutes

Elements from the text

A domestic statute is briefed from its text, and the mechanism is an elements list. You fill 4 boxes and you leave a box blank rather than invent it: the conduct, the mental state, the object of the conduct, and the consequence the text states. A news summary that mentions only 2 of the 4 boxes is not your brief. You cite the section number beside each box you filled.

You apply the brief to 1 fact pattern in a memo of fixed shape. The pattern is short: an employee copied 2 files from a system they were allowed to use, after hours. You ask which element, if any, those facts satisfy, and you say when an element is not met. You do not add a fifth element from a commentator. Global or domestic, the brief stays tied to the words you read.

Four boxes, each tied to a section.

Conduct the text names

Mental state the text names

Object of that conduct

Consequence the text states

Two files, four boxes

1. The fact pattern is one employee and 2 files on a system they could already use. You open the

statute, not a news recap.

2. You fill only the boxes the section supports, and you cite the section number. A news note that covers 2 boxes is not the brief.

3. If the mental-state box is not in the text, you leave it blank. You do not import a fifth element from a commentator.

Problem 1. A news summary states 2 elements and skips the mental state and the consequence. How many boxes of your brief does that summary fill by itself?

Answer. None you may rely on. The brief's 4 boxes come from the statute text, with a section number beside each filled box. A summary that mentions 2 boxes is not the brief.

Problem 2. The fact pattern is 2 copied files on a system the employee was allowed to use. May you add a fifth element from a commentator because the hours were late?

Answer. No. You test the 4 elements that are in the text and you say when one is not met. Late hours are part of the fact pattern, not a new element. One memo, one fact pattern.

Lecture 6 · 90 minutes

Two duties that do not average

A cross-border flow can sit under 2 regimes at once. The mechanism is to list each regime's duty separately, then choose an action that satisfies both. Suppose regime A requires log retention of at least 180 days and regime B requires deletion of the same log at day 90. Those two duties conflict, and you do not average them to 135. You escalate the conflict as a legal question.

You track where the bytes sit, because location can change the duty. A backup copied into a second country is a second processing site, not a harmless spare. If 1 of your 4 backups crosses that border, you have a cross-border flow even though 3 copies stayed home. You record the site, the regime, and the retention number you are actually using. Three columns beat a map with no numbers.

Write both duties before you pick an action.

Regime A

Keep the log 180 days

Retention is the duty

Do not average with B

Regime B

Delete the log at day 90

Deletion is the duty

Escalate the conflict

One backup of four

1. You have 4 backups. One is copied into a second country, so you have a cross-border flow. The other 3 do not erase that fact.

2. Regime A says retain at least 180 days. Regime B says delete at day 90. The average 135 satisfies neither text.

3. You record site, regime, and the retention number you are actually using, and you escalate. You do not pick 135 because it sits in the middle.

Problem 1. Regime A requires at least 180 days of retention and regime B requires deletion at day 90. What is the average, and why do you refuse it?

Answer. The average is 135 days, because 180 plus 90 is 270, and 270 divided by 2 is 135. You refuse it because 135 meets neither duty. You escalate the conflict.

Problem 2. Four backups exist and 1 of them is copied into a second country. How many copies create a cross-border flow?

Answer. 1 copy is enough. The other 3 staying home does not cancel the flow. You record the site, the regime, and the retention number in 3 columns.

Lecture 7 · 90 minutes

A folder with dates

Policy courses go stale when they rely on news, so your mechanism is a primary-source folder with a date. You keep 2 kinds of documents: official guidance, such as a CISA publication, and a statute or regulatory text. A video recap is not in the folder. For each document you store the title, the issuer, and the date you read it, which is 3 fields. If the date is missing, you cannot tell whether a 2022 draft was replaced.

Stanford's Center for Internet and Society is a second primary shelf, useful for argument about doctrine, not as a substitute for the statute. You still brief 1 statute or 1 incident, not both in the same memo. An incident brief uses 4 headings: what happened, which duty applied, what the clock required, and what was actually done. Filling those headings from a news article alone leaves you with hearsay.

What goes in the folder before a brief.

Store issuer and date -> Prefer the statute text -> Add CISA guidance -> Brief one subject only

One incident, four headings

1. You open an official timeline and a statute, each with title, issuer, and the date you read it. A 2022 draft without a read-date is not citable yet.

2. The memo is an incident brief, not also a statute brief. The 4 headings are what happened, which duty, what the clock required, and what was done.

3. A news article can sit outside the folder. Stanford's Center for Internet and Society may inform the doctrine paragraph, and it does not replace the duty heading.

Problem 1. Your folder has a CISA document with a title and an issuer, and no date read. What can you not tell a later reader?

Answer. Whether that copy was already replaced, for example whether a 2022 draft is still current. The 3 fields are title, issuer, and date read. A video recap does not fill them.

Problem 2. You filled all 4 incident headings from one news article. What is wrong with the brief?

Answer. The headings are hearsay until an official timeline or the statute supports them. You brief 1 incident or 1 statute, not both in the same memo, and a news folder is not the course.

Lecture 8 · 90 minutes

What you can now brief

You can now write policy that someone could violate, test, and sign. A requirement names a number, such as 90 days of logs or a 72-hour notice. Governance names 3 roles, and a missing signature is not silence. A statute brief has 4 elements taken from the text. Two regimes that demand 180 days and 90 days are a conflict you escalate, not an average of 135.

The reading path is CISA's public guidance and Stanford's Center for Internet and Society, plus the statute itself. You do not finish this course with a folder of news videos. Your closing product is 1 brief, either on 1 statute or on 1 incident, with the 4 headings filled from primary text. If a heading is supported only by a headline, this course is not finished. The cross-list name CYBR 602 does not change that standard.

Close on one brief a stranger can check.

1. Pick statute or incident

2. Fill four headings

3. Cite issuer and date

4. Drop headline-only lines

Ninety days, or seventy-two hours

1. You can fail a procurement term: 90 days required, 10 days delivered, shortfall 80. You can subtract a notice clock: hour 80 minus hour 72 is 8.

2. You can refuse the average of 180 and 90, which is 135, and you can count signatures out of 3.

3. The closing brief uses primary text. CISA guidance and Stanford's Center for Internet and Society are the shelves. A headline-only heading means the course is not finished.

Problem 1. Regime A says 180 days and regime B says 90 days. What number do people reach by averaging, and what do you do instead?

Answer. 135. You do not adopt 135. You list both duties and escalate the conflict. The closing brief is still 1 statute or 1 incident, with 4 headings from primary text.

Problem 2. Discovery is at hour 0, notice is at hour 80, and the rule is 72 hours. The brief's clock heading cites only a headline. What is the overrun, and is the brief done?

Answer. The overrun is 8 hours, because 80 minus 72 is 8. The brief is not done. A heading supported only by a headline fails the course standard, including for CYBR 602.